

110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 09 月 25 日

第 1 頁，共 9 頁

單選題 50 題 (佔 100%)

B	1. 關於資訊安全「可用性」的定義，下列敘述何者正確？ (A) 確保資訊的正確和完全性 (B) 確保資訊在需要時可被存取和使用 (C) 確保資訊在傳輸過程中已確認兩方的身分和合法性 (D) 確保資訊不會被揭露或被未經授權的個人、實體和流程所取得
C	2. 資訊安全管理系統 (Information Security Management System, ISMS) 是在於管理面的要求，藉由審查機制、事件的回應及內部稽核來預防資訊安全事件或是降低其損失的風險，請問下列敘述何者「不」正確？ (A) 需要管理階層的承諾及提供相關支援，表達對資訊安全管理系統的支持 (B) 採用規劃 (Plan)、執行 (Do)、檢查 (Check) 及行動 (Act) 等四個階段的改進流程進行 (C) 資訊安全目標無需具體量化，導入解決方案、強化資訊安全防護為指導方針 (D) 內部稽核的成果報告需要在管理審查會議中進行檢討
B	3. 資訊安全管理系統 (Information Security Management System, ISMS) 中的風險評估 (Risk Assessment) 作業，屬於規劃 (Plan)、執行 (Do)、檢查 (Check) 及行動 (Act) 循環中的哪一部分？ (A) 規劃 (Plan) (B) 執行 (Do) (C) 檢查 (Check) (D) 行動 (Act)
C	4. 建立或導入資訊安全管理系統 (Information Security Management System, ISMS) 時，最重要的第一個步驟為下列何者？ (A) 資訊資產清冊盤點 (B) 資訊安全滲透測試 (C) 資訊安全管理系統範圍的決定 (D) 實施必要的控制措施
D	5. 關於機敏性 (Confidentiality)，下列敘述何者「不」正確？ (A) 資訊不得在未授權的情況下對外揭露 (B) 資訊於儲存、傳輸過程中應採取加密措施 (C) 個人資料如帳號、密碼、信用卡卡號等資訊外洩為機敏性可能面臨之風險 (D) 機敏性資料僅有在駭客攻擊時才會面臨的風險
D	6. 下列何者為規範個人資料之蒐集、處理及利用，以避免人格權受侵

110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 09 月 25 日

第 2 頁，共 9 頁

	害，並促進個人資料之合理利用的法規？ (A) 電子簽章法 (B) 妨害電腦使用罪 (C) 著作權法 (D) 個人資料保護法
B	7. 畢業後返校申請在校成績單，是行使個資法的何種權利？ (A) 請求刪除 (B) 請求製給複製本 (C) 請求補充 (D) 請求停止處理
B	8. 若要實施資訊安全管理系統 (Information Security Management System, ISMS)，第三方驗證公司是依據下列何種 ISO 標準進行驗證？ (A) ISO/IEC 27000 :2013 (B) ISO/IEC 27001 :2013 (C) ISO/IEC 27002 :2013 (D) ISO/IEC 27003 :2013
C	9. 關於「資通安全事件通報及應變辦法」內容，下列敘述何者「不」正確？ (A) 資安事件共分四等級 (B) 資安事件等級中，第四級為最重大，第一級為最輕微 (C) 該辦法規定只有公務機關遇資安事件時需要通報 (D) 若為第一級資安事件，公務機關應於知悉後 72 小時內完成通報
A	10. 下列何者是我國個人資料保護法與歐盟一般資料保護規範 (General Data Protection Regulation, GDPR) 有較相同的規定？ (A) 資料刪除權 (B) 資料可攜權 (C) 引進新科技之個資處理方式時需進行資料保護影響評估 (D) 資料保護長制度
A	11. 下列何者為隱私保護的適當做法？ (A) 以電子郵件傳輸個人資料時，先將個人資料加密 (B) 將公司的員工通訊錄公開於網路上 (C) 直接將大量的個人資料儲存在隨身碟 (D) 直接將大量的個人資料燒錄在光碟中
C	12. 下列何者「不」是個人隱私保護需涵蓋的範圍？ (A) 個人資料

110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 09 月 25 日

第 3 頁，共 9 頁

	(B) 身體特徵 (C) 公司地址 (D) 通訊內容
D	13. 某生在學校宿舍內架設網站，分享從網路上下載的音樂或影片，並且提供同學下載，請問侵犯了下列何種法規？ (A) 營業秘密法 (B) 智慧財產權法 (C) 個人資料保護法 (D) 著作權法
B	14. 關於資訊資產，下列敘述何者「不」正確？ (A) 資產指的是任何對組織有價值的事物 (B) 資產包含有型的事物，資訊包含無形的事物 (C) 資訊也是資產的一種 (D) 資訊可以以很多不同的形式存在
B	15. 關於資訊安全管理之資訊資產清冊，下列敘述何者「不」正確？ (A) 資產的重要性應與所支援的業務有關 (B) 運用資產管理軟體掃描可省去確認程序 (C) 資訊資產應依據其類型進行分類 (D) 資產的重要性依其支援業務的重要性而有差異
D	16. 關於資訊資產擁有者（Owner）在資產管理的工作描述，下列敘述何者「不」正確？ (A) 確保資產已盤點與造冊 (B) 確保資產已適切分級並受保護 (C) 當資產刪除或銷毀資產時，確保已適當清除與處理 (D) 例行工作應親自執行，不可指派他人執行
B	17. 關於資訊資產分級，下列敘述何者較正確？ (A) 資訊資產分級之主要目的是方便組織進行資產登記與報廢 (B) 資訊資產分級之主要目的是協助組織定義資訊資產對組織的重要性 (C) 資訊資產的採購金額愈高，對組織的重要性一定愈高 (D) 人員不屬於資訊資產應評估的對象
C	18. 若要保護機敏資料，關於可攜式媒體（如：USB 隨身碟）的管理，下列敘述何者較「不」適當？ (A) 將可攜式媒體儲存於安全的環境 (B) 將可攜式媒體上的敏感資料進行加密 (C) 不將可攜式媒體登載於資產清冊上

110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 09 月 25 日

第 4 頁，共 9 頁

	(D) 不需使用的可攜式媒體，應將所儲存的資料徹底移除
D	19. 關於資訊資產之擁有、保管與使用，下列敘述何者正確？ (A) 使用者負責獲得適當的授權，得以存取或異動資訊資產 (B) 擁有者對於資訊資產負有管理的責任，通常由各使用者擔任 (C) 使用者負責資訊資產的相關處理與保管工作 (D) 資訊資產之擁有、保管與使用的權責，應由各部門權責主管指定適當之擁有者、保管者與使用者
C	20. 下列何者「不」屬於資訊資產？ (A) 人事資料 (B) 電腦 (C) 辦公桌椅 (D) 套裝軟體
C	21. 關於資訊資產分級的目的，下列敘述何者較為正確？ (A) 確保組織安全責任 (B) 限制對資訊的存取 (C) 確保資產依組織之重要性，受到適切等級的保護 (D) 確保系統運作的完整性
D	22. 關於殘餘風險 (Residual Risk)，下列敘述何者正確？ (A) 單位可以承受的風險 (B) 沒有被識別的風險 (C) 已經被識別，但是沒有指定處置方法的風險 (D) 執行風險處理措施後，還殘留下來的風險
A	23. 關於風險辨識 (Risk Identification)，下列敘述何者正確？ (A) 是發掘可能發生風險之事件及其發生之原因和方式 (B) 是組織進行風險評鑑、分析與評估的整體流程 (C) 是理解風險本質並且決定風險等級的流程 (D) 是比較風險分析結果與風險準則來決定風險或嚴重程度是否為可接受的流程
C	24. 若在執行定期風險評鑑進入尾聲時發現一項新的風險議題，下列何者較「不」適當？ (A) 將該風險議題納入此次風險評鑑，一併完成評鑑 (B) 針對該風險議題額外執行風險評鑑並出具報告 (C) 因定期風險評鑑有完成期限，故對此風險議題不做處理 (D) 先初步評估該風險議題是否有重大影響，若無重大影響則於事後再進行完整評估
D	25. 關於風險評鑑 (Risk Assessment)，下列敘述何者較「不」正確？

110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 09 月 25 日

第 5 頁，共 9 頁

	(A) 是一種風險管理的機制 (B) 是將預估的風險和已知風險準則進行比較的過程 (C) 目的是決定可接受風險的程度 (D) 目的是將可接受的風險與主要風險分開，並移除殘餘風險
A	26. 發生資安事件攻擊時，若其損失在組織可容忍範圍，可採取下列何種風險處置策略？ (A) 風險接受 (Acceptance) (B) 風險降低 (Reduction) (C) 風險移轉 (Transfer) (D) 風險避免 (Avoidance)
B	27. 使用網路銀行轉帳或付款時，銀行要求提供手機號碼傳送臨時驗證碼到手機，再請你輸入驗證碼後確認轉帳程序；請問本題中的「手機」屬於下列何種驗證要素？ (A) Something you know (B) Something you have (C) Something you are (D) Something you see
B	28. 某線上交易網站遭人利用電腦程式重複不斷登入，不僅加重伺服器負載量，亦妨礙到正常使用者，因此資安專家建議可利用圖片辨識做為認證機制，以確保登入者是人類而非機器及電腦程式，請問這位專家建議採用的技術為下列何者？ (A) Akismet (B) CAPTCHA (C) 二階段驗證 (Two-Step Verification) (D) 雙因子認證 (Two-Factor Authentication)
D	29. 身分認證技術是為了核對使用者的身分是否正確，以利提供相對應的權限，請問下列何種認證方式較難以偽造？ (A) 6 位的密碼 (數字) 認證 (B) 6 位的密碼 (數字及英文字母大小寫) + 智慧卡認證 (C) 6 位的密碼 (數字、英文字母大小寫及特殊符號) 認證 (D) 運用視網膜 (Retina) 進行認證
D	30. 關於生物特徵認證中之 CER、FRR 與 FAR 三種評比指標，下列敘述何者「不」正確？ (A) CER：交叉錯誤率，集合 FRR 及 FAR 兩個曲線的交叉點 (B) FRR：錯誤拒絕率，把對的驗證為錯誤的屬於 Type I error (C) FAR：錯誤接受率，把錯誤的驗證為對的屬於 Type II error (D) 生物特徵認證，最好的是 CER 及 FAR 愈高的愈好

110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 09 月 25 日

第 6 頁，共 9 頁

B	31. 如果運用生物特徵來做身分認證，生物特徵可區分為靜態特徵及動態特徵，請問下列哪些屬於「靜態特徵」？(1)指紋、(2)聲音模式、(3)視網膜 (A) (1)(2) (B) (1)(3) (C) (2)(3) (D) (1)(2)(3)
B	32. 關於身分認證及權限管理，下列敘述何者較「不」恰當？ (A) 使用者應妥善保管 IC 卡，不可任意外借他人使用 (B) 不定期清查帳號與權限 (C) 任何使用者均需輸入帳號及密碼，以進行使用者身分鑑別 (D) 專案或工作結束時，應刪除與系統營運或維護無關之帳號
D	33. 下列何者「不」是單一登入（Single Sign-On, SSO）的特點？ (A) 集中權限控管 (B) 降低不同帳號密碼記憶的困擾 (C) 減少重新輸入密碼的程序 (D) 簡訊認證
B	34. 關於存取控制，下列敘述何者較「不」適當？ (A) 使用防火牆區隔內外網路，將公司對外全球網站放置於 DMZ 區（Demilitarized Zone），並關閉非必要的連接埠 (B) 使用網段區隔技術，隔離敏感系統、重要機密的工作群組以及各類別的職務群組，但為了通聯及工作的便利性，內部網路各網段應直接互相通聯 (C) 機密檔案加密系統的使用者依不同的工作性質設定群組權限，非該群組成員無法開啟其加密檔案 (D) 重要系統設定其使用者超過一段時間未動作即會自動登出
C	35. 下列何者「不」是應用系統安全防護的三大核心（AAA）？ (A) Authentication (B) Authorization (C) Availability (D) Accounting
B	36. 關於區塊加密法（Block Cipher），下列敘述何者「不」正確？ (A) 區塊加密採用多輪運算（Iteration） (B) 多輪運算中，每輪使用的金鑰都是主金鑰 (C) 金鑰長度不一定要跟區塊大小相同 (D) 加密演算法與解密演算法應互為反函式

110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 09 月 25 日

第 7 頁，共 9 頁

A	37. 若明文為「WE ARE DISCOVERED FLEE AT ONCE」，使用凱撒密碼偏移量為 6，密文應為下列何者？ (A) CKG XK JOYIU BKXKJ LRKKG ZUTIK (B) IQMDQ PUEOA HQDQP RXQQM FAZOQ (C) OWSJW VAKUG NWJWV XDWWS LGFUW (D) UCYPC BGQAM TCPCB DJCCY RMLAC
A	38. 關於網站加密協定，下列敘述何者「不」正確？ (A) TLS 1.0 以下的協定版本存在降級攻擊（Downgrade Attack）的風險 (B) SSL 與 TLS 1.0 差距相當微小，可視 TLS 為 SSL 標準化的版本 (C) TLS 的優勢在於與應用層協定（HTTP、FTP、Telnet 等）無耦合關係存在，因此應用層可透明的於 TLS 基礎上傳遞資料 (D) TLS 1.3 為目前最新版本的網站加密協定，針對降級攻擊（Downgrade Attack）進行修正
B D	39. 關於對稱式加密（Symmetric Encryption），下列敘述何者「不」正確？ (A) 對稱式加密特色為加解密速度快，若使用長金鑰具備相對較高之安全性 (B) 對稱式加密金鑰管理是重要的課題，若有 N 位使用者，則需 $N \times (N-1)$ 金鑰數目 (C) 對稱式加密中，金鑰的管理極為重要，為決定安全性之根本之一 (D) 對稱式演算法可以驗證檔案所有人身分
D	40. 關於非對稱式加密（Asymmetric Encryption），下列敘述何者「不」正確？ (A) 非對稱式加密又稱公私鑰加密，顧名思義具有公鑰與私鑰，公鑰可公開，私鑰則須妥善保管 (B) 傳送方於傳送時可利用私鑰進行加密，接收方利用公鑰則可驗證檔案所有人 (C) 公鑰與私鑰為成對存在 (D) 若有 N 個使用者，則須 N+1 對金鑰（公鑰與私鑰為一對）
B	41. 關於資安事件發生時的緊急應變措施，下列敘述何者「不」正確？ (A) 依訂定之緊急應變計畫，實施緊急應變處置，並持續監控與追蹤管制 (B) 一定要緊急關閉電腦，防止資安事件發生 (C) 視資安事件損壞程度啟動備援計畫、異地備援或備援中心等應變措施，以防止事件擴大 (D) 評估資安事件對業務運作造成之衝擊，並進行損害管制

110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 09 月 25 日

第 8 頁，共 9 頁

C	42. 資安事件緊急應變處置最重要目的為下列何者？ (A) 用防火牆或網站應用程式防火牆（Web Application Firewall, WAF）做偵測跟阻擋 (B) 採用弱掃工具或滲透測試服務驗證是否完成修補 (C) 控制受害範圍 (D) 立即使用資料復原即可
D	43. 關於資安事件（Event）與資安事故（Incident）留存紀錄，下列敘述何者較「不」正確？ (A) 事件與事故都可以進行趨勢分析 (B) 發生資安事故時，資安事件可協助分析與處置 (C) 都可作為符合法規之證據 (D) 資安事故才須留紀錄，資安事件無需留存，以節省成本
A	44. 關於事件紀錄，下列敘述何者正確？ (A) 組織應制定政策規範紀錄格式，使其保持一致 (B) 紀錄應盡量簡要，不應有時間、事件摘要之外的資訊 (C) 事件資訊一經紀錄，便不能被任何人修改，以維持其權威性 (D) 資安十分複雜，紀錄者只能依個人專業判斷事件等級
D	45. 關於事件處理的移除或復原，下列敘述何者「不」正確？ (A) 根據鑑識分析報告，修補事件成因 (B) 根據各種被利用之弱點，盤點其影響程度及範圍 (C) 修補後也應盤點確認，以確保修補作業順利 (D) 應完成修補避免再度受駭，不可選擇執行系統重建
A	46. 若固定每星期日執行一次完整備份（Full Backup），之後每天會備份從上次完整備份到目前所異動的內容，此種備份方式稱為下列何者？ (A) 差異備份（Differential Backup） (B) 增量備份（Incremental Backup） (C) 循環備份（Circulatory Backup） (D) 緊急備份（Emergency Backup）
C	47. 關於復原點目標（Recovery Point Objective, RPO），下列敘述何者正確？ (A) 可以忍受多久的業務中斷 (B) 資料回復的時間點與資料量無關 (C) 以可容許資料損失時間與資料量，進行備份計畫評估 (D) 投入資源越多，恢復越慢
A	48. 關於營運持續計畫（Business Continuity Plan, BCP）之目的，下列敘述何者較「不」正確？

110 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：110 年 09 月 25 日

第 9 頁，共 9 頁

	(A) 營運持續計畫是一套基於業務運行規律的管理要求和規範流程 (B) 業務持續性是指企業有應對風險、自動調整和快速反應的能力 (C) 將災難造成的影響減少至最小程度，確保業務流程能及時地繼續運行 (D) 制訂和實施應變計畫，確保在要求的時間內恢復業務流程
C	49. 關於營運測試，下列敘述何者正確？ (A) 平行測試：在實際作業環境中進行測試 (B) 完全中斷測試：於備援平台上進行測試 (C) 模擬測試：建立模擬環境並於其中測試 (D) 結構化排練測試：權責單位各自討論處理方式與可行性
B	50. 關於災害復原計畫（Disaster Response Planning, DRP）之目的，下列敘述何者「不」正確？ (A) 將災害造成的影響減少至最小程度 (B) 分析災害、安全缺失和服務損失的後果 (C) 採取必要的措施來確保業務能正常執行 (D) 回復資訊的完整，並確保資訊系統正常運作